

Lecture 45 : Denial of Service Attack

Introduction

In an increasingly interconnected digital world, the availability of online services is paramount. From accessing critical information on websites to communicating via email, users expect seamless and uninterrupted access to digital resources. However, this accessibility is constantly threatened by malicious actors employing Denial of Service (DoS) and Distributed Denial of Service (DDoS) attacks. These attacks represent a significant challenge to cybersecurity, aiming to disrupt normal operations, render services unavailable, or severely degrade their performance. Understanding the mechanics, types, and mitigation strategies of DoS and DDoS attacks is crucial for anyone involved in maintaining or securing digital infrastructure. This lecture delves into the intricacies of these disruptive cyber threats, providing a foundational understanding of how they operate and how to defend against them.

Core Concepts

Term	Definition	Significance
DoS Attack	A Denial of Service attack aims to make a resource unavailable to its legitimate users by overwhelming it with requests from a single source, causing it to crash or slow down.	Represents a fundamental threat to service availability, demonstrating how a single point of origin can disrupt digital operations.
DDoS Attack	A Distributed Denial of Service attack is a more sophisticated form where multiple compromised systems (a botnet) flood a target with traffic, making it unavailable.	Highlights the increased scale and complexity of modern attacks, making them harder to trace and mitigate due to their distributed nature.
Botnet	A network of internet-connected devices, such as computers or IoT devices, that have been infected with malware and are controlled remotely by an	Serves as the backbone for DDoS attacks, enabling attackers to launch large-scale, coordinated assaults

Term	Definition	Significance
	attacker without the owners' knowledge.	that can generate immense traffic volumes.
Volume-based Attack	A category of DDoS attacks that aims to saturate the target's bandwidth with a massive flood of traffic, often measured in bits per second.	Focuses on overwhelming the network infrastructure, preventing legitimate traffic from reaching the target by consuming all available capacity.
Protocol-based Attack	DDoS attacks that exploit weaknesses in network protocols (Layers 3 and 4) to consume server resources or intermediate network devices like firewalls and load balancers.	Targets the operational capacity of network devices and server resources, measured in packets per second, leading to system instability or crashes.
Application Layer Attack	DDoS attacks that target specific vulnerabilities or functionalities within an application (Layer 7), aiming to crash the web server or overload specific application processes.	Mimics legitimate user behavior, making detection difficult, and focuses on exhausting application-specific resources, measured in requests per second.
Slowloris	A specific application layer attack that sends numerous HTTP headers to a web server but never completes the requests, keeping connections open until the server's connection pool is exhausted.	Illustrates a subtle yet effective method of DoS that doesn't require high bandwidth but exploits server resource limitations, leading to denial of service.
SYN Flood	A protocol-based attack where an attacker sends a rapid succession of SYN requests to a target server, but never completes the TCP handshake,	A classic and potent attack that exploits the TCP three-way handshake, leading to network congestion and server resource depletion.

Term	Definition	Significance
	exhausting the server's connection table.	
Ping of Death	An older protocol-based attack involving sending malformed or oversized ICMP packets (larger than 65,535 bytes) to a target, causing memory overflow and system crashes.	Demonstrates how exploiting protocol limits can lead to severe system instability, though modern systems are largely patched against this specific vulnerability.
Zero-day DDoS	A DDoS attack that exploits a previously unknown vulnerability in a system or application for which no patch or fix has yet been released by the vendor.	Represents a highly dangerous and unpredictable threat, as defenses are not yet in place, making these attacks particularly challenging to mitigate.

Detailed Analysis

1. Understanding DoS and DDoS Attacks

A **Denial of Service (DoS) attack** is a cyber-attack designed to make a machine or network resource unavailable to its intended users. This is typically achieved by overwhelming the target with a flood of traffic or requests from a single source, causing the server to become unresponsive, crash, or operate at an extremely slow pace. The core principle is to deny legitimate users access to a resource, such as a website, network, or email service.

In contrast, a **Distributed Denial of Service (DDoS) attack** is a more potent and complex variant. Instead of a single source, a DDoS attack leverages multiple compromised systems, often distributed globally, to generate a massive flood of traffic. These compromised systems form what is known as a **botnet**. Attackers build botnets by spreading malicious code through various channels like emails, websites, and social media. Once infected, these machines can be controlled remotely without their owners' knowledge, acting as an "army" to launch a coordinated attack against a target. The distributed nature of a DDoS attack makes it significantly harder to defend against, as the sheer volume of traffic can measure in tens of gigabits per second, far exceeding the capacity of a normal network. DDoS floods can manifest as an overwhelming number of connection requests, or a deluge

of random data designed to consume the target's bandwidth, ultimately leading to a complete blockage of service.

2. Categorization of DDoS Attacks

DDoS attacks are broadly categorized into three main types, each targeting different layers of the network stack:

- **Volume-based Attacks (Layer 3 & 4 Attacks):** These attacks aim to saturate the bandwidth of the target site by generating an enormous volume of traffic. The magnitude of these attacks is typically measured in bits per second.
- **TCP Flood:** Overwhelms the target with a high volume of TCP packets.
- **UDP Flood:** Floods random ports on a remote host with numerous UDP packets, often targeting port 53. Specialized firewalls can help filter these.
- **ICMP Flood:** Similar to UDP floods, this involves sending numerous ICMP echo requests (ping requests) to a remote host, consuming both incoming and outgoing bandwidth and slowing down the system.
- **HTTP Flood:** Attackers send a large volume of HTTP GET and POST requests to a targeted web server, exceeding its capacity to handle legitimate connections.
- **Amplification Attack:** The attacker sends a small request to a service (e.g., DNS, NTP) that generates a much larger response, directing this amplified response to the target. Examples include DNS requests for large PHT records or HTTP GET requests for large files.
- **Protocol-based Attacks (Layer 3 & 4 Attacks):** These attacks consume actual server resources and other network infrastructure resources like firewalls and load balancers. Their magnitude is measured in packets per second.
- **SYN Flood:** Attackers send TCP connection requests (SYN packets) faster than the targeted machine can process them. The attacker does not complete the three-way handshake, leaving the server waiting for an ACK, thus exhausting its connection table. Mitigation involves reducing connection timeouts or selectively dropping incoming connections.
- **DNS Flood:** Targets both the infrastructure and the DNS application to overwhelm the system and consume available network bandwidth.
- **Ping of Death:** Attackers send malformed or oversized packets (larger than the IP maximum of 65,535 bytes) using a simple ping command. This violates the internet protocol and can cause memory overflow, leading to a

system crash. Many firewalls block ICMP ping messages to prevent such attacks.

- **Fragmented Packet Attacks:** Exploits the reassembly process of fragmented packets.
- **Application Layer Attacks (Layer 7 Attacks):** These attacks target specific vulnerabilities or functionalities within an application, aiming to crash the web server. Their magnitude is measured in requests per second. These are particularly difficult to detect because they often resemble legitimate website traffic.
- **Application Attack:** Involves making resource-intensive requests like exclusive logins, database lookups, or search queries to overload the application.
- **Slowloris:** The attacker sends a huge number of HTTP headers to a targeted web server but never completes the request. The server keeps these incomplete connections open, eventually exhausting its maximum concurrent connection pool and denying additional connections from legitimate clients.
- **NTP Amplification:** Exploits publicly accessible Network Time Protocol (NTP) services to overwhelm the targeted server with User Datagram Protocol (UDP) traffic.
- **Zero-day DDoS Attacks:** These attacks exploit a "zero-day vulnerability," which is a system or application flaw previously unknown to the vendor and for which no patch has yet been released. These are new and evolving types of attacks.

3. DDoS Protection and Mitigation Strategies

Defending against DDoS attacks requires a multi-faceted approach. The initial steps involve strengthening the target system itself:

- * **Vulnerability Management:** Identify and close all possible operating system and application-level vulnerabilities.
- * **Port Management:** Close all unnecessary ports.
- * **Access Control:** Remove unnecessary access permissions from the system.
- * **Infrastructure Hiding:** Hide servers behind a proxy or Content Delivery Network (CDN) system.

For low-magnitude DoS attacks, firewall-based solutions can effectively filter out malicious traffic. However, for high-volume DDoS attacks (gigabytes or more), a more robust solution is required. Engaging a specialized DDoS protection service provider is often necessary. Caution is advised when selecting such providers, as

some may exploit the urgency of an attack by offering services at unreasonably high costs.

A practical and effective solution involves a combination of services:

1. **DNS Solution Provider:** Choose a flexible DNS provider capable of configuring A and CNAME records for your website.
2. **CDN Provider:** Select a reputable CDN provider that can handle peak DDoS traffic and offers DDoS protection services as part of their package. CDNs distribute traffic and can absorb large volumes of malicious requests before they reach the origin server.

4. Practical Demonstration: Performing a Slowloris Attack

The lecture includes a practical demonstration of performing a DoS attack using the Slowloris script. This involves identifying a vulnerable target and then executing the attack.

Step 1: Identify Target and Check Vulnerability

First, a target web application running on a specific IP address (e.g., 192.168.0.104) is identified. To determine if the server is vulnerable to Slowloris, the `nmap` tool is used with a specific script:

```
nmap -T4 --script http-slowloris-check 192.168.0.104
```

If the `nmap` scan indicates that the `http-slowloris-check` finds the target vulnerable, the attack can proceed.

Step 2: Obtain the Slowloris Script

The Slowloris script, typically a Perl script, can be downloaded from the internet. The demonstration shows how to clone it from a repository using `git` :

```
git clone [URL_of_slowloris_script_repository]
```

This command downloads the script, for example, `slowloris.pl` , to the local file system.

Step 3: Execute the Slowloris Attack

Once the script is downloaded, navigate to its directory in the terminal. Since it's a Perl script, it's executed using the `perl` interpreter, specifying the target IP address or domain name:

```
perl slowloris.pl -dns 192.168.0.104
```

Upon execution, the script begins sending numerous packets to the target application. The demonstration shows the script successfully sending hundreds, then thousands of packets, with threads sleeping periodically before sending more.

Step 4: Observe the Impact

After the Slowloris script has been running for some time, attempting to access the target web application (e.g., `192.168.0.104`) will reveal that it is no longer accessible. This confirms the successful execution of the DoS attack, as the server's connection pool has been exhausted, denying service to legitimate clients.

Key Takeaways

- [] DoS attacks originate from a single source, while DDoS attacks leverage multiple distributed sources (botnets).
- [] Botnets are networks of compromised machines controlled remotely by attackers to launch large-scale attacks.
- [] DDoS attacks are categorized into volume-based, protocol-based, and application layer attacks, each targeting different network layers.
- [] Volume-based attacks aim to saturate bandwidth, measured in bits per second, including TCP, UDP, ICMP, and HTTP floods, and amplification attacks.
- [] Protocol-based attacks consume server and network device resources, measured in packets per second, such as SYN floods and Ping of Death.
- [] Application layer attacks target specific application vulnerabilities, measured in requests per second, and are difficult to detect due to mimicking legitimate traffic (e.g., Slowloris, Zero-day DDoS).
- [] Effective DDoS protection involves vulnerability management, port closure, access control, and hiding servers behind proxies or CDNs.
- [] For high-volume DDoS attacks, specialized DDoS protection service providers or a combination of flexible DNS and robust CDN services are recommended.
- [] Tools like `nmap` can be used to check for specific vulnerabilities, such as Slowloris, before attempting an attack.
- [] The Slowloris attack demonstrates how an application layer attack can deny service by exhausting a server's connection pool with incomplete HTTP requests.

Conclusion

Denial of Service and Distributed Denial of Service attacks represent a persistent and evolving threat in the digital landscape. Their ability to disrupt critical services,

from e-commerce platforms to essential government websites, underscores the importance of robust cybersecurity measures. As attackers continually refine their methods, leveraging sophisticated botnets and exploiting new vulnerabilities, the strategies for defense must also adapt. The shift from simple DoS to complex, multi-vector DDoS attacks necessitates a layered defense approach, combining internal system hardening with external protection services like CDNs and specialized DDoS mitigation providers. Understanding the different attack vectors—whether they target bandwidth, network protocols, or application logic—is fundamental to designing effective countermeasures. The practical demonstration of a Slowloris attack highlights that even seemingly simple techniques can have significant impact, emphasizing the need for continuous vigilance and proactive security postures to ensure the availability and integrity of online resources for all legitimate users.